STRIDE ISP 2.6 – GV.SC

Supply Chain Risk Management Standards

Version [2.0]

Purpose:

This document defines the Stride standards related to Supply Chain Risk Management.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	6/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
2.0	01/28/2025	- Major change to align with NIST 2.0 - Previous document titled and filed under ID.SC shifted to GV.SC and rebuilt to accommodate alignment with NIST 2.0
2.0	02/24/2025	- Approved Mark Williams - CISO
2.0	02/27/2025	- Published

SUPPLY CHAIN RISK MANAGEMENT STANDARDS

Supply chain risk management processes are identified, established, managed, monitored, and improved by organizational stakeholders.

GV.SC-01 SUPPLY CHAIN RISK MANAGEMENT PROGRAM

A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders.

Standards:

Supply Chain & Third-Party Risk Management Strategy and Implementation:

- An organization-wide strategy for Supply Chain and Third-Party Risk Management (SC&TPRM) is developed, documented, and implemented.

- The SC&TPRM Program is managed by the Governance, Risk, and Compliance (GRC) Team and supported by other internal resources as needed, such as Legal, Human Resources, Information Technology, and School Services.

Documentation and Access:

- All Supply Chain and Third-Party Risk Management activities, assessments, and inventories are documented within the Governance, Risk, and Compliance solution, serving as a repository of past, current, and future state TPRM assessments.

- Access is granted to authorized personnel only.

- Vendors or service providers are only removed from the GRC platform after notification from Stride Procurement unless otherwise governed by regulatory or legal retention requirements.

Review and Update:

- Supply Chain & Third-Party Risk Management processes, policies, and standards are reviewed at least annually or when significant enterprise changes occur that could impact this safeguard.

Comprehensive TPRM Strategy:

- Stride implements a comprehensive third-party risk management strategy and program designed to identify, assess, and manage risks associated with third-party relationships throughout their lifecycle. This approach ensures timely risk mitigation, particularly for sector-critical systems and operations, while aligning with Stride's risk appetite.

- As part of this strategy, Stride regularly evaluates the aggregated risk of its third-party relationships, considering factors such as critical service dependencies, vendor concentration, geographical and geopolitical exposure, fourth-party risks, and financial sector interdependencies.

- The program encompasses the classification, inventory, assessment, monitoring, and decommissioning of service providers to ensure effective oversight and management. Service providers are assessed in accordance with Stride's service provider management policy. Assessments may include:

    - Standardized assessment reports such as Service Organization Control (SOC 1 and SOC 2) reports

    - Payment Card Industry (PCI) Attestation of Compliance (AoC)

    - Customized questionnaires

    - Other rigorous evaluation methods

References:

- CIS Controls v8.0: 15.2

- CRI Profile v2.0: GV.SC-01

- CRI Profile v2.0: GV.SC-01.01

- CRI Profile v2.0: GV.SC-01.02

- SP 800-221A: GV.PO-1

- CSF v1.1: ID.SC-1

GV.SC-02 THIRD-PARTY ROLES AND RESPONSIBILITIES

Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally.

Standards:

Role Assignment and Responsibilities:

- Stride assigns specific roles and positions to ensure effective planning, resourcing, and execution of cybersecurity supply chain risk management activities.

- The designated roles are responsibilities for:
    - Developing and implementing cybersecurity supply chain risk management strategies.
    - Allocating necessary resources to mitigate risks.
    - Executing and monitoring supply chain risk management processes.
- Cybersecurity responsibilities for all personnel at Stride are documented and defined to ensure clarity and accountability. This includes:
    - Assigning specific cybersecurity tasks and duties to individual roles.
    - Providing clear documentation of responsibilities to all employees.
    - Ensuring accountability through regular performance reviews and audits.

External Stakeholder Roles:

- Suppliers:
    - Adhere to Stride's cybersecurity standards, including data protection, secure development practices, and incident response protocols.
    - Participate in regular security audits and provide evidence of compliance.
- Customers:
    - Safeguard shared data and adhere to user access policies.
    - Report potential security incidents that may affect Stride.
- Business Partners:
    - Protect interconnected systems and notify Stride of vulnerabilities or breaches that could have an impact.
    - Align with joint cybersecurity initiatives and participate in mutual training exercises.

Documentation and Agreements:

- Stride incorporates these roles and responsibilities into organizational policies and formalizes them in third-party agreements, such as contracts and service-

level agreements (SLAs). This ensures all parties are aware of their obligations and provides a framework for accountability.

- Cybersecurity requirements and responsibilities for all company personnel are documented, ensuring that:
    - All workforce members and third-party stakeholders understand their duty to report suspected cybersecurity incidents or breaches.
    - Confidentiality of organizational information is maintained by all members of the workforce.

References:

- SP 800-218: PO.2.1
- CIS Controls v8.0: 15.4
- CRI Profile v2.0: GV.SC-02
- CRI Profile v2.0: GV.SC-02.01
- SP 800-221A: GV.RR-1
- SP 800-221A: GV.RR-2
- CSF v1.1: ID.AM-6

GV.SC-03 SUPPLY CHAIN RISK MANAGEMENT INTEGRATION

Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes.

Standards:

Identification and Evaluation:

- Suppliers and partners critical to Stride's systems, components, and services are identified, prioritized, and evaluated through a Supply Chain and Third-Party Risk Assessment process based on their role in delivering high-value services.
- Threats and vulnerabilities affecting Stride's systems are assessed in the context of the cyber supply chain and vendor relationships.
- The linkelihood, severity, and impact of potential attacks on vendors or suppliers are analyzed to determine their implications for Stride's operations.

Categorization Framework:

- Service providers are categorized using a classification framework that considers factors such as:
    - Data Sensitivity
    - Data Volume
    - Availability Requirements
    - Applicable Regulations
    - Inherent Risk
    - Mitigated Risk

Review and Update

- Service providers, vendor classifications, and assessments are reviewed and updated annually or following significant changes at Stride that could affect these safeguards.

Alignment with Broader Frameworks:

- Stride's third-party risk management strategy aligns with and reinforces its broader enterprise, technology, cybersecurity, and resilience risk management frameworks and programs.

References:

- SP 800-218: PW.4.1
- CRI Profile v2.0: GV.SC-03
- CRI Profile v2.0: GV.SC-03.01
- SP 800-221A: GV.CT-2
- SP 800-221A: GV.CT-3
- CSF v1.1: ID.SC-2

GV.SC-04 SUPPLIER IDENTIFICATION AND PRIORITIZATION

Suppliers are known and prioritized by criticality.

Standards:

Inventory and Categorization:

- Stride maintains an up-to-date inventory of all third-party suppliers and partners, categorizing them based on their role in delivering critical systems, services, or components.

Assessment and Prioritization:

- All suppliers are assessed and prioritized according to their criticality and the potential impact of a compromise. Factors considered include data sensitivity, volume, availability requirements, applicable regulations, inherent and mitigated risks, and contract value.

Security and Compliance Requirements:

- Stride establishes and enforces security and compliance requirements for all suppliers through contractual agreements. These requirements address cybersecurity standards, incident reporting protocols, information-sharing rules, and ongoing monitoring expectations.

Supplier Classification:

- Suppliers are classified based on their risk profile, and this classification guides the level of oversight, monitoring, and assessment required throughout the supplier relationship lifecycle.

References:

- SP 800-218: PW.4.1
- CRI Profile v2.0: GV.SC-03
- CRI Profile v2.0: GV.SC-03.01
- SP 800-221A: GV.CT-2
- SP 800-221A: GV.CT-3
- CSF v1.1: ID.SC-2

GV.SC-05 THIRD-PARTY CONTRACTS AND AGREEMENTS

Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and agreements with suppliers and relevant third parties.

Standards:

Comprehensive Security Requirements:

- Service provider contracts must incorporate comprehensive security requirements and undergo periodic reviews or updates as necessary. These contracts establish baseline protections and effectively manage risks throughout the third-party relationship, ensuring compliance and vigilance to maintain the security and integrity of organizational data and operations.

Defined Rights and Responsibilities:

- Contracts explicitly define the rights and responsibilities of all parties and address potential risks that may arise during the relationship. The organization must identify, document, and agree on expected cybersecurity practices for critical third parties, ensuring alignment with the organization's risk management objectives.

Security Requirements:

- Minimum security program standards.
- Notification and response protocols for security incidents or data breaches.
- Data encryption and secure handling requirements.
- Data disposal obligations.

Contract Terms:

- Mutual Non-Disclosure Agreement (NDA) signed by all relevant parties.
- Scope of Business Relationship clearly defined, including services provided.
- Primary Points of Contact, including security personnel for incident response and threat mitigation.
- Incident reporting Service Level Agreement (SLA).
- Adherence to relevant security frameworks with evidence of operational security practices and program maturity.

- Addresses data handling, retention, and disposal after contract expiration.

Review and Update:

- Service provider contracts are reviewed annually or as needed to ensure all necessary security clauses are included, establishing baseline protections to manage risk over the life of the third-party relationship.

Specification and Agreement:

- Clearly specify the rights and responsibilities of each party and establish requirements to address anticipated risks.

- Identity, document, and agree on expected cybersecurity practices for critical third parties, aligning with the organization's risk management objectives.

References:

- SP 800-218: PO.1.3

- CIS Controls v8.0: 15.4

- CRI Profile v2.0: EX.CN

- CRI Profile v2.0: EX.CN-01

- CRI Profile v2.0: EX.CN-02

- CRI Profile v2.0: EX.CN-01.01

- CRI Profile v2.0: EX.CN-01.02

- CRI Profile v2.0: EX.CN-01.03

- CRI Profile v2.0: EX.CN-02.01

- CRI Profile v2.0: EX.CN-02.02

- CRI Profile v2.0: EX.CN-02.03

- CRI Profile v2.0: EX.CN-02.04

- CSF v1.1: ID.SC-3

GV.SC-06 PROCUREMENT PLANNING AND DUE DILIGENCE

Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships.

Standards:

Procurement Planning:

- Planning is conducted for procurements and agreements that pose significant risks to Stride, including:
    - Evaluating potential risks such as data security, compliance, operational dependencies, and financial exposure.
    - Developing detailed contracts, defining performance metrics, and establishing contingency plans.

Due Diligence:

- Stride carries out comprehensive due diligence on potential third parties, aligned with procurement planning and proportionate to the risk, importance, and complexity of each third-party relationship. This includes:
    - Verifying certifications and compliance (e.g., PCI DSS, SOC 2).
    - Reviewing independent audit reports.
    - Evaluating security practices.
    - Obtaining references or performance reviews.

SC&TPRM Strategy:

- A comprehensive, organization-wide strategy for Supply Chain and Vendor Risk Management (SC&TPRM) is developed, documented, and implemented at Stride.

Standards:

- CIS Controls v8.0: 15.5
- CRI Profile v2.0: EX.DD
- CRI Profile v2.0: EX.DD-01

- CRI Profile v2.0: EX.DD-02
- CRI Profile v2.0: EX.DD-01.01
- CRI Profile v2.0: EX.DD-01.02
- CRI Profile v2.0: EX.DD-01.03
- CRI Profile v2.0: EX.DD-02.01
- CRI Profile v2.0: EX.DD-02.02
- CRI Profile v2.0: EX.DD-02.03
- CRI Profile v2.0: EX.DD-02.04
- SP 800-221A: GV.PO-1
- CSF v1.1: ID.SC-1

GV.SC-07 MONITORING AND MANAGING SUPPLIERS

The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship.

Standards:

Service Delivery Monitoring:

- Supplier or vendor service delivery is monitored, regularly reviewed, and audited for compliance with established contract terms and agreements.
- Monitoring, reviews, and audits on supplier or vendor services are conducted by Risk Management personnel in accordance with internal policies and procedures.

Assessment Consistency:

- Service providers are assessed consistently with the enterprise's Supply Chain and Third-Party Risk Management policy and procedures.

Compliance Actions:

- Stride may take any of the following actions to determine ongoing compliance with security requirements, as they relate to the relationship with business partners in the cyber supply chain:

- Conduct control assessments by internal or external parties to determine compliance with relevant security standards.
- Contract a third-party provider to conduct audit activities on a supplier or vendor to demonstrate compliance with security requirements and mandates.
- Review and analyze audit records for indications of inappropriate or unusual activities.
- Develop plans for ongoing security and privacy assessments that verify, through testing and evaluation, the continued compliance and security of the cyber supply chain partner.
- Review of risk management and governance processes to ensure alignment with Stride's overall stance on security and requirements related to business partnerships.

Assessment Scope:

- Assessment scope will vary based on classification(s) and may include a review of standardized assessment reports, such as SOC 2 and PCI AoC, penetration test results, customized questionnaires, or other appropriately rigorous processes.

Ongoing Monitoring:

- Critical suppliers and third parties are monitored to confirm that they continue to satisfy their obligations as required; reviews of audits, test results, or other assessments of third parties are conducted.

References:

- SP 800-218: PW.4.1
- SP 800-218: PW.4.4
- CIS Controls v8.0: 15.6
- CRI Profile v2.0: EX.MM
- CRI Profile v2.0: EX.MM-01
- CRI Profile v2.0: EX.MM-02

- CRI Profile v2.0: EX.MM-01.01
- CRI Profile v2.0: EX.MM-01.02
- CRI Profile v2.0: EX.MM-01.03
- CRI Profile v2.0: EX.MM-01.04
- CRI Profile v2.0: EX.MM-01.05
- CRI Profile v2.0: EX.MM-01.06
- CRI Profile v2.0: EX.MM-02.01
- CRI Profile v2.0: EX.MM-02.02
- CRI Profile v2.0: EX.MM-02.03
- SP 800-221A: GV.CT-2
- SP 800-221A: GV.CT-3
- SP 800-221A: MA.RM-2
- SP 800-221A: MA.RM-3
- CSF v1.1: ID.SC-2
- CSF v1.1: ID.SC-4

GV.SC-08 THIRD-PARTY INCIDENT MANAGEMENT INTEGRATION

Relevant suppliers and other third parties are included in incident planning, response, and recovery activities.

Standards:

Testing Requirements:

- Stride requires associated business partners to provide results from the testing, including the following:
    - Contingency Plans and/or Business Continuity Plans: To determine the organization's effectiveness and readiness in the event of a disruption in normal operations.

- Incident Response Plan: To assess the effectiveness and capabilities of resolving ongoing incidents and threats to the operating environment.
- Business Impact Analysis and/or Criticality Analysis: To identify critical services and assess the impact on the organization if those services cease operation.

Internal Testing and Assessment:

- Stride personnel, including cross-functional teams and departments, may test, assess, and report on the efficacy of vendor or supplier response and recovery plans.

Documentation and Availability:

- Documentation of tests, assessments, and reports related to response and recovery are centrally hosted and available to authorized personnel.

Information Confidentiality:

- Stride does not release information on vendors' or suppliers' response and recovery capabilities unless legally required to do so through legal subpoena.

Review and Update:

- Response and recovery assessments are reviewed and updated at least yearly to ensure relevance and currency.

References:

- CIS Controls v8.0: 15.4
- CRI Profile v2.0: GV.SC-08
- CRI Profile v2.0: GV.SC-08.01
- SP 800-221A: GV.CT-3
- CSF v1.1: ID.SC-5

GV.SC-09 SUPPLY CHAIN SECUIRTY PRACTICE INTEGRATION

Supply chain security practices are integrated into cybersecurity and enterprise risk

management programs, and their performance is monitored throughout the technology product and service lifecycle.

Standards:

Attention to Third-Party Risks:

- Specific attention is given to the risks and requirements associated with third-party dependencies, including their contracts, operations, and interactions.

- Stride prioritizes designing, operating, monitoring, and improving its policies, procedures, and controls to meet business needs within the organization's risk appetite.

Vendor Security Assessments:

- Stride conducts thorough security assessments of vendors before onboarding, ensuring they align with our security standards.

Contractual Security Clauses:

- Vendor contracts are structured to include robust security clauses, such as breach notification timelines, data protection measures, and compliance with frameworks like NIST or ISO 27001.

Ongoing Monitoring:

- Stride employs ongoing monitoring of third-party vendors to identify and address vulnerabilities in real-time.

Policy Revisions:

- Stride regularly revisits its supply chain security policies and procedures to adapt to evolving threats.

Collaborative Relationships:

- Stride fosters collaborative relationships with key third parties to ensure alignment on security objectives.

References:

- CIS Controls v8.0: 15.6

- CRI Profile v2.0: GV.SC-09
- CRI Profile v2.0: GV.SC-09.01
- SP 800-221A: GV.PO-1
- CSF v1.1: ID.SC-1

GV.SC-10 RELATIONSHIP TERMINATION

Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement.

Standards:

Proactive Planning:

- Stride proactively anticipates and prepares for the conclusion of critical third-party relationships, whether under standard conditions or adverse situations. Planning ensures a smooth transition, mitigates risks, and safeguards Stride's assets and data throughout the termination process.

Termination Procedures:

- Clear termination procedures are defined, including steps to follow during the conclusion of the relationship, communication protocols, and timelines.

Data Handling and Security:

- Data handling and security of all sensitive or proprietary data is securely returned, transferred, or permanently destroyed per Stride's policies and applicable regulations.
- Maintain a detailed inventory of assets (e.g., hardware, software licenses, documentation, intellectual property) to ensure proper tracking and retrieval during termination.

Access Termination:

- Promptly terminate physical and digital access to Stride's systems, facilities, and resources to prevent unauthorized access after the relationship ends, per Stride policies.

- Continue monitoring for suspicious activities that may indicate misuse of residual access during the transition period.

Legal and Contractual Obligations:

- Adhere to all relevant legal and contractual obligations, such as data protection regulations, non-disclosure agreements, and service level agreements.

Stakeholder Notification:

- Notify key stakeholders, including employees, leadership, and impacted third parties, about the termination and its implications.

Post-Termination Review:

- Conduct a post-termination review to identify lessons learned, document the process, and refine policies for future terminations.

References:

- CIS Controls v8.0: 15.7
- CRI Profile v2.0: EX.TR
- CRI Profile v2.0: EX.TR-01
- CRI Profile v2.0: EX.TR-02
- CRI Profile v2.0: EX.TR-01.01
- CRI Profile v2.0: EX.TR-01.02
- CRI Profile v2.0: EX.TR-01.03
- CRI Profile v2.0: EX.TR-02.01
- SP 800-221A: GV.PO-1
- CSF v1.1: ID.SC-1